

COMPIRA - Historias de Usuario

Tabla 1. Product backlog del módulo de autenticación (reordenado)

ID HU	Nombre de la historia de usuario	Sprint	Prioridad	Story points	Estado	Criterio de aceptación (resumen)
HU-01	Cambio obligatorio de contraseña en el primer inicio de sesión	S1	Alta	5	Completado	Gestiona el desafío <code>NEW_PASSWORD_REQUIRED</code> y activa la cuenta con una contraseña personal.
HU-02	Inicio de sesión con correo y contraseña	S1	Alta	5	Completado	Autentica credenciales válidas y determina el siguiente paso (tokens o desafío).
HU-03	Verificación en dos pasos mediante código OTP por correo	S1	Alta	5	Completado	Completa el segundo factor con el desafío <code>EMAIL_OTP</code> (código de 6 dígitos).
HU-04	Reenvío del código OTP de acceso	S1	Media	2	Completado	Permite reenviar el OTP tras cumplirse el tiempo de espera.
HU-05	Solicitud de recuperación de contraseña por correo	S2	Alta	3	Completado	Envía el código de recuperación al correo registrado.
HU-06	Confirmación del restablecimiento de contraseña con código	S2	Alta	5	Completado	Confirma el código y restablece la contraseña.
HU-07	Cierre de sesión y control de acceso a rutas protegidas	S2	Alta	3	Completado	Protege rutas internas y limpia la sesión al salir.
HU-08	Registro de usuarios por parte del administrador	S3	Alta	5	Completado	Crea usuarios con rol y contraseña temporal.
HU-09	Eliminación de usuarios por correo	S3	Media	3	Completado	Elimina usuarios con confirmación previa.

El campo **Estado** se mantiene según el documento base (presencia de rutas, pantallas, contratos y casos de uso observables en el repositorio). No fue modificado por esta corrección.

1. Historias de usuario detalladas

HU-01. Cambio obligatorio de contraseña en el primer inicio de sesión

Sprint S1 | Prioridad Alta | 5 story points | Estado Completado

HISTORIA DE USUARIO - HU-01	
Nombre:	Cambio obligatorio de contraseña en el primer inicio de sesión
Puntos de historia (story points):	5
Como (rol):	usuario registrado del sistema (administrador, coordinador o colaborador) que ingresa por primera vez con una contraseña temporal
Quiero (funcionalidad):	establecer mi propia contraseña personal antes de acceder a la plataforma
Para (beneficio):	activar mi cuenta con una credencial segura y bajo mi control

Contexto funcional

Cuando un administrador crea un usuario (ver HU-08), la cuenta queda con una **contraseña temporal** y en estado que obliga a cambiarla. En el primer inicio de sesión, Cognito responde al login con `status = CHALLENGE_REQUIRED` y `challengeName = NEW_PASSWORD_REQUIRED`. El sistema redirige al usuario a la pantalla **Crea tu nueva contraseña** (`/auth/new-password`) y no le permite continuar hasta definir una contraseña válida. Es el primer paso obligatorio del ciclo de vida de una cuenta.

Campos / Datos involucrados

Campo	Tipo / Control	Obligatorio	Descripción
Nueva contraseña	Texto (password, con mostrar/ocultar)	Sí	Ingresa la nueva contraseña. Longitud 10-128 caracteres en la UI.
Confirmar contraseña	Texto (password)	Sí	Repetir la contraseña. Debe coincidir exactamente con la anterior.
session	Dato de contexto (no editable)	Sí	Sesión del desafío devuelta por el login; se transporta internamente, no la ingresa el usuario.

Política de contraseña indicada al usuario en pantalla (tooltip de criterios):

- Mínimo 10 caracteres.
- Al menos una letra mayúscula.
- Al menos una letra minúscula.
- Al menos un número.
- Al menos un carácter especial (!@#\$%^&*).

Criterios de Aceptación

CA 1. Redirección obligatoria al desafío de cambio

Cuando el usuario inicia sesión con una contraseña temporal y el login responde `challengeName = NEW_PASSWORD_REQUIRED`, el sistema lo redirige a la pantalla de nueva contraseña y no le permite acceder a ninguna ruta protegida hasta completar el cambio.

CA 2. Bloqueo del envío hasta cumplir longitud y coincidencia

El botón de envío permanece deshabilitado mientras la nueva contraseña no tenga entre 10 y 128 caracteres o mientras "Nueva contraseña" y "Confirmar contraseña" no coincidan. Si no coinciden, se muestra el mensaje "Las contraseñas no coinciden".

CA 3. Cambio exitoso que completa el acceso

Cuando el usuario envía una contraseña que cumple la política de Cognito y este responde `AUTHENTICATED`, el sistema guarda la sesión (tokens y datos de usuario) y lo redirige a la pantalla principal (/).

CA 4. Cambio exitoso que encadena un segundo desafío

Cuando tras el cambio Cognito responde nuevamente `CHALLENGE_REQUIRED` con `EMAIL_OTP` (o `SMS_MFA`), el sistema conduce al usuario a la pantalla de verificación (/auth/verify) con la nueva `session`, sin dar por finalizado el acceso.

CA 5. Rechazo por política de contraseña no cumplida

Cuando la contraseña cumple la longitud pero no la política de Cognito (mayúscula/minúscula/número/símbolo), el sistema muestra el mensaje devuelto por el backend ("La contraseña no cumple con la política definida en Cognito", código `AUTH_002`) y no cambia la credencial.

CA 6. Acceso directo inválido a la pantalla

Cuando se intenta abrir `/auth/new-password` sin una `session` y un correo válidos en el contexto, el sistema redirige a la pantalla de inicio de sesión.

DEFINICIÓN DE TERMINADO (DoD)

- ☐ Código revisado y aprobado por el equipo (code review)
- ☐ Prueba funcional ejecutada y aprobada (caso de prueba documentado)
- ☐ Evidencia visual integrada en el diario de sprint
- ☐ Criterios de aceptación verificados y marcados
- ☐ Sin deuda técnica conocida asociada a esta HU

Reglas de negocio

RN 1. El cambio de contraseña en primer ingreso es obligatorio; el usuario no puede omitirlo ni acceder a la aplicación sin completarlo.

RN 2. La contraseña definitiva debe cumplir la política configurada en el pool de Cognito. La política oficial vigente en Cognito es información **[Pendiente]** de confirmar (ver Preguntas pendientes).

Escenario exitoso

Usuario ingresa con contraseña temporal -> Cognito devuelve `NEW_PASSWORD_REQUIRED` -> usuario define y confirma la nueva contraseña -> Cognito responde `AUTHENTICATED` -> sistema guarda la sesión y muestra la pantalla principal.

Escenarios de error

Situación	Comportamiento del sistema	Mensaje / código
Contraseñas no coinciden	Mantiene el formulario, no envía	"Las contraseñas no coinciden" (UI)
Contraseña no cumple política de Cognito	No cambia la credencial	<code>AUTH_002</code> - "La contraseña no cumple con la política definida en Cognito"
Sesión de desafío expirada o inválida	Error de challenge	<code>AUTH_012</code> - "La solicitud del reto de autenticación no es válida"
Error inesperado	Muestra mensaje genérico	"Ocurrió un error inesperado. Intenta nuevamente."

Consideraciones técnicas funcionales

- Endpoint: `POST /api/v1/auth/login/challenge`.
- Request: `{ email, session, challengeName: "NEW_PASSWORD_REQUIRED", newPassword }`.
- Response: `AuthResponse { status, user, tokens, challenge }`.
- El backend traduce el desafío a `RespondToAuthChallenge` de Cognito con `challengeResponses = { USERNAME, NEW_PASSWORD }`.

Requerimientos no funcionales

- Seguridad: la contraseña viaja solo por HTTPS; no se registra en logs (el backend enmascara correo y sesión).
- Trazabilidad: el backend registra inicio, éxito y fallo de la operación con datos enmascarados.

Aclaraciones

- **[Recomendación]** La UI bloquea el envío únicamente por longitud (10-128) y coincidencia; los indicadores de mayúscula/minúscula/número/símbolo son informativos. Se recomienda alinear la validación del cliente con la política real de Cognito para evitar que el usuario reciba el error `AUTH_002` tras enviar. Esto no es un criterio de aceptación hasta ser aprobado.
- El backend valida la nueva contraseña con longitud 8-128, mientras la UI exige mínimo 10. Se recomienda unificar el mínimo.

Fuera de alcance

- Cambio de contraseña voluntario desde el perfil de un usuario ya autenticado (no existe en el flujo revisado).
- Expiración periódica de contraseñas.

Mockup requerido

Sí. Ver sección de mockups (M-01).

compira.app/auth/new-password

COMPIRA
Gestión segura

Inicio
Empresas
Usuarios

HU-01

Crea tu nueva contraseña

Es tu primer inicio de sesión. Define una contraseña personal para continuar.

Nueva contraseña

.....

Criterios de seguridad

☐ 10+ caracteres ☐ Mayúscula ☐ Minúscula
☐ Número ☐ Carácter especial

Confirmar contraseña

.....

! Las contraseñas no coinciden.

Guardar y continuar

Mockup funcional

Estados cubiertos

- Botón bloqueado si falta información
- Error de coincidencia o política
- Acceso directo o continuación a OTP

Mockup funcional HU-01. Incluye los estados principales de uso, validación y error. Elaboración propia (2026).

Dependencias

- Depende de HU-08 (registro de usuario con contraseña temporal), que deja la cuenta en estado de cambio obligatorio.
- Depende de la configuración de política de contraseñas en el pool de Cognito.

Preguntas pendientes

1. ¿Cuál es la política exacta de contraseñas configurada en Cognito (longitud mínima, clases de caracteres requeridas)? La UI muestra mínimo 10 y el backend valida mínimo 8.
2. ¿La contraseña temporal tiene fecha de expiración configurada en Cognito? Si expira antes del primer ingreso, ¿qué mensaje debe ver el usuario?

HU-02. Inicio de sesión con correo y contraseña

Sprint S1 | Prioridad Alta | 5 story points | Estado Completado

HISTORIA DE USUARIO - HU-02	
Nombre:	Inicio de sesión con correo y contraseña
Puntos de historia (story points):	5
Como (rol):	usuario registrado del sistema (administrador, coordinador o colaborador)
Quiero (funcionalidad):	iniciar sesión con mi correo electrónico y mi contraseña
Para (beneficio):	acceder a la plataforma de forma segura y continuar con mis actividades según el rol asignado

Contexto funcional

Es el punto de entrada a la plataforma (/auth/login). El usuario ingresa correo y contraseña; el sistema autentica contra Cognito (InitiateAuth, flujo USER_PASSWORD_AUTH). Según la respuesta, el sistema puede: (a) emitir tokens y dar acceso directo, (b) exigir cambio de contraseña obligatorio (HU-01), o (c) exigir el segundo factor por OTP (HU-03).

Campos / Datos involucrados

Campo	Tipo / Control	Obligatorio	Descripción
Correo electrónico	Texto (email)	Sí	Ingresa el correo registrado.
Contraseña	Texto (password, con mostrar/ocultar)	Sí	Ingresa la contraseña.

- El botón "Iniciar sesión" permanece deshabilitado mientras el correo o la contraseña estén vacíos.
- Enlace visible "Recuperar contraseña" que lleva a HU-05.

Criterios de Aceptación

CA 1. Acceso directo con credenciales válidas sin desafíos

Cuando el usuario ingresa credenciales válidas y Cognito responde `AUTHENTICATED`, el sistema guarda la sesión y lo redirige a la pantalla principal (/).

CA 2. Desvío a cambio obligatorio de contraseña

Cuando Cognito responde `CHALLENGE_REQUIRED` con `NEW_PASSWORD_REQUIRED`, el sistema redirige a `/auth/new-password` (HU-01).

CA 3. Desvío a verificación en dos pasos

Cuando Cognito responde `CHALLENGE_REQUIRED` con `EMAIL_OTP` o `SMS_MFA`, el sistema redirige a `/auth/verify` (HU-03).

CA 4. Rechazo por credenciales inválidas

Cuando el correo o la contraseña son incorrectos, el sistema muestra "Las credenciales ingresadas no son válidas" (`AUTH_005`) y no otorga acceso.

CA 5. Rechazo por estado de la cuenta

Cuando la cuenta no está confirmada, el sistema muestra "La cuenta aún no ha sido confirmada" (`AUTH_006`).

Cuando Cognito exige restablecer la contraseña, muestra "Debes restablecer la contraseña antes de iniciar sesión" (`AUTH_008`).

DEFINICIÓN DE TERMINADO (DoD)

- ☐ Código revisado y aprobado por el equipo (code review)
- ☐ Prueba funcional ejecutada y aprobada (caso de prueba documentado)
- ☐ Evidencia visual integrada en el diario de sprint
- ☐ Criterios de aceptación verificados y marcados
- ☐ Sin deuda técnica conocida asociada a esta HU

Reglas de negocio

RN 1. El rol del usuario se determina automáticamente al autenticar (se refleja en la nota de la pantalla: "El sistema asignará tu rol automáticamente al iniciar sesión").

Escenarios de error

Situación	Mensaje / código
Credenciales inválidas	<code>AUTH_005</code> - "Las credenciales ingresadas no son válidas"
Cuenta no confirmada	<code>AUTH_006</code> - "La cuenta aún no ha sido confirmada"
Requiere reset de contraseña	<code>AUTH_008</code> - "Debes restablecer la contraseña antes de iniciar sesión"
Datos vacíos o formato inválido	<code>AUTH_014</code> - "La solicitud contiene datos inválidos o incompletos"
Demasiados intentos	<code>AUTH_013</code> - "Se recibieron demasiadas solicitudes. Inténtalo nuevamente en unos minutos"

Consideraciones técnicas funcionales

- **Endpoint:** `POST /api/v1/auth/login`. **Request:** `{ email, password }`. **Response:** `AuthResponse { status, user, tokens, challenge }`.

- Flujo Cognito: USER_PASSWORD_AUTH.

Requerimientos no funcionales

- Seguridad: doble factor de autenticación habilitado; la contraseña no se almacena en el cliente.
- Trazabilidad: el backend registra el resultado del login con correo enmascarado.

Aclaraciones

- El campo correo usa `type=email` pero el formulario tiene `noValidate`; la validación de formato definitiva la realiza el backend.

Fuera de alcance

- Inicio de sesión con proveedores externos (Google, SSO, etc.).
- Selección manual de canal MFA y verificación por SMS: el enum existe en backend pero el frontend actual solo expone OTP por correo.

Mockup requerido

Sí. Ver M-02.

Mockup funcional HU-02. Incluye los estados principales de uso, validación y error. Elaboración propia (2026).

Dependencias

- Cognito configurado con el cliente de aplicación y flujo USER_PASSWORD_AUTH.

Preguntas pendientes

1. ¿Existe un límite de intentos fallidos con bloqueo temporal de la cuenta, o el control queda delegado a Cognito?

HU-03. Verificación en dos pasos mediante código OTP por correo

Sprint S1 | Prioridad Alta | 5 story points | Estado Completado

HISTORIA DE USUARIO - HU-03	
Nombre:	Verificación en dos pasos mediante código OTP por correo
Puntos de historia (story points):	5
Como (rol):	usuario registrado del sistema (administrador, coordinador o colaborador)
Quiero (funcionalidad):	confirmar mi identidad con un código de verificación enviado a mi correo
Para (beneficio):	completar el acceso con verificación en dos pasos y proteger mi cuenta

Contexto funcional

Tras el login (o tras el cambio obligatorio de contraseña), cuando Cognito devuelve el desafío `EMAIL_OTP`, el sistema muestra la pantalla **Verifica tu identidad** (`/auth/verify`). El usuario ingresa el código de 6 dígitos recibido por correo para completar la autenticación y recibir los tokens.

Campos / Datos involucrados

Campo	Tipo / Control	Obligatorio	Descripción
Código OTP	6 campos de un dígito (solo numéricos)	Sí	Ingresar el código de 6 dígitos. Soporta autoavance, retroceso y pegado.
<code>session</code>	Dato de contexto	Sí	Sesión del desafío; no la ingresa el usuario.
Destino enmascarado	Texto informativo (solo lectura)	N/A	Muestra el correo destino del código (<code>codeDeliveryDetails.destination</code>).

Criterios de Aceptación

CA 1. Verificación exitosa

Cuando el usuario ingresa correctamente el código de 6 dígitos y Cognito responde `AUTHENTICATED`, el sistema guarda los tokens y datos de usuario y lo redirige a la pantalla principal (`/`).

CA 2. Habilitación del envío solo con código completo

El botón de verificación permanece deshabilitado hasta que los 6 dígitos estén diligenciados.

CA 3. Código inválido

Cuando el código es incorrecto, el sistema muestra "El código de confirmación es inválido" (AUTH_003), limpia los 6 campos y devuelve el foco al primero, manteniendo bloqueado el acceso.

CA 4. Código expirado

Cuando el código venció, el sistema muestra "El código de confirmación expiró" (AUTH_004) y no completa la autenticación.

CA 5. Acceso directo inválido a la pantalla

Cuando se intenta abrir `/auth/verify` sin `session` y correo válidos, el sistema redirige a la pantalla de inicio de sesión.

DEFINICIÓN DE TERMINADO (DoD)
☐ Código revisado y aprobado por el equipo (code review)
☐ Prueba funcional ejecutada y aprobada (caso de prueba documentado)
☐ Evidencia visual integrada en el diario de sprint
☐ Criterios de aceptación verificados y marcados
☐ Sin deuda técnica conocida asociada a esta HU

Reglas de negocio

RN 1. El código OTP tiene exactamente 6 dígitos numéricos.

Escenarios de error

Situación	Mensaje / código
Código incorrecto	AUTH_003 - "El código de confirmación es inválido"
Código expirado	AUTH_004 - "El código de confirmación expiró"
Falta el código en la solicitud	AUTH_012 - "Debes enviar el código de verificación para completar el reto seleccionado"

Consideraciones técnicas funcionales

- Endpoint: `POST /api/v1/auth/login/challenge`. Request: { email, session, challengeName: "EMAIL_OTP", code }.
- Backend traduce a `challengeResponses = { USERNAME, EMAIL_OTP_CODE }`.

Requerimientos no funcionales

- Seguridad: el segundo factor protege el acceso incluso si la contraseña fue comprometida.

Aclaraciones

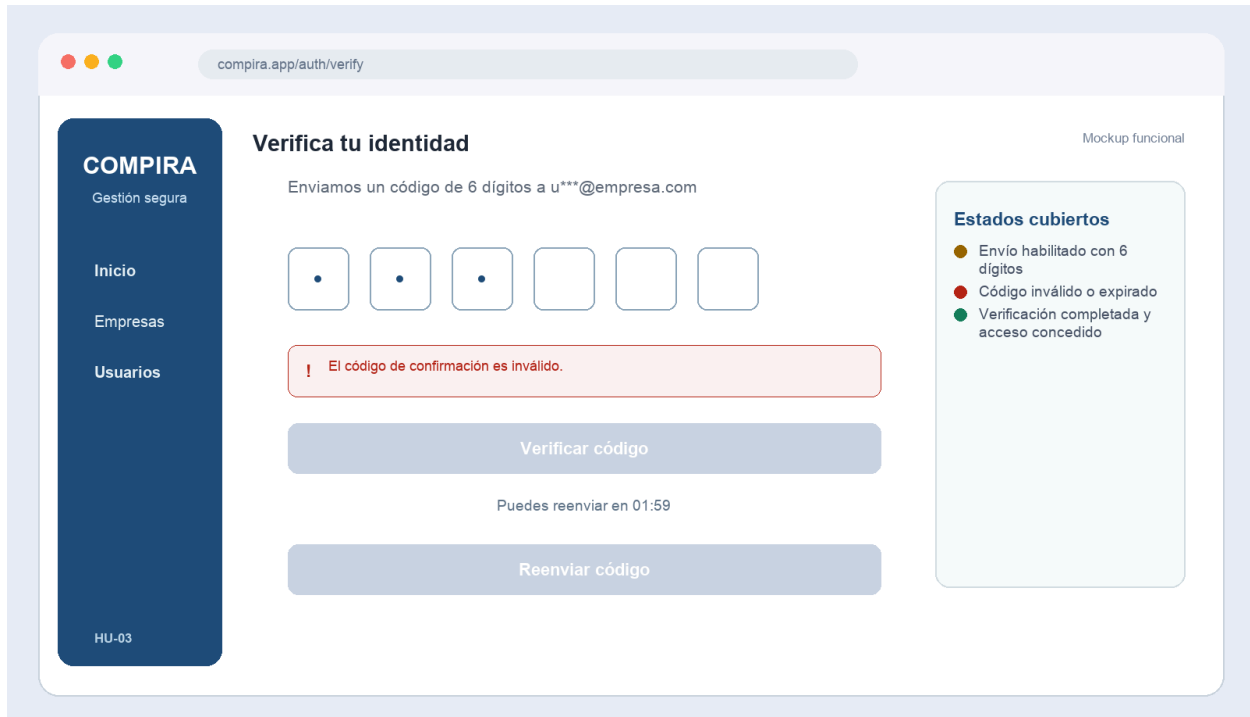
- El destino mostrado proviene de `codeDeliveryDetails.destination` (correo enmascarado por Cognito); si no está disponible, se muestra el correo ingresado.

Fuera de alcance

- Verificación por SMS (SMS_MFA) y selección de canal (SELECT_MFA_TYPE): soportados en el enum del backend pero no expuestos en el frontend actual.

Mockup requerido

Sí. Ver M-03.



Mockup funcional HU-03. Incluye los estados principales de uso, validación y error. Elaboración propia (2026).

Dependencias

- Depende del inicio de sesión (HU-02) o del cambio de contraseña (HU-01) que originan el desafío.
- Cognito con MFA por correo (SES) habilitado.

Preguntas pendientes

1. ¿Cuál es el tiempo de vigencia del código OTP configurado en Cognito?

HU-04. Reenvío del código OTP de acceso

Sprint S1 | Prioridad Media | 2 story points | Estado Completado

HISTORIA DE USUARIO - HU-04	
Nombre:	Reenvío del código OTP de acceso
Puntos de historia (story points):	2
Como (rol):	usuario registrado del sistema (administrador, coordinador o colaborador)
Quiero (funcionalidad):	solicitar el reenvío del código OTP cuando no lo reciba
Para (beneficio):	continuar el proceso de autenticación sin reiniciar todo el ingreso

Contexto funcional

En la pantalla de verificación (`/auth/verify`), si el usuario no recibe el código, puede solicitar uno nuevo una vez transcurrido el tiempo de espera. Mientras el contador está activo se muestra el tiempo restante; al llegar a cero aparece la opción "Reenviar código".

Campos / Datos involucrados

Campo	Tipo / Control	Obligatorio	Descripción
Reenviar código	Acción (botón)	N/A	Disponible solo cuando el contador llega a 0.
Contador de espera	Texto informativo (mm:ss)	N/A	Cuenta regresiva; valor inicial 120 segundos por defecto (<code>VITE_OTP_RESEND_COOLDOWN_SECONDS</code>).

Criterios de Aceptación

CA 1. Reenvío disponible tras el tiempo de espera

Cuando el contador de espera llega a 0 y el usuario selecciona "Reenviar código", el sistema solicita un nuevo código, reinicia el contador a 120 segundos, limpia los campos del código y devuelve el foco al primero.

CA 2. Reenvío bloqueado durante el tiempo de espera

Mientras el contador es mayor que 0, la opción de reenvío no está disponible y se muestra el tiempo restante en formato mm:ss.

CA 3. Rechazo del servicio

Cuando Cognito rechaza el reenvío (por ejemplo, por exceso de solicitudes), el sistema conserva el flujo y muestra el mensaje de error correspondiente sin autenticar la sesión.

DEFINICIÓN DE TERMINADO (DoD)
☐ Código revisado y aprobado por el equipo (code review)
☐ Prueba funcional ejecutada y aprobada (caso de prueba documentado)
☐ Evidencia visual integrada en el diario de sprint
☐ Criterios de aceptación verificados y marcados
☐ Sin deuda técnica conocida asociada a esta HU

Reglas de negocio

RN 1. El tiempo de espera del cliente antes de permitir un nuevo reenvío es de 120 segundos por defecto, configurable por variable de entorno.

Escenarios de error

Situación	Mensaje / código
Demasiadas solicitudes	AUTH_013 - "Se recibieron demasiadas solicitudes. Inténtalo nuevamente en unos minutos"
Usuario no encontrado	AUTH_007 - "No se encontró una cuenta asociada al usuario enviado"
Error genérico	"No se pudo reenviar el código." (UI)

Consideraciones técnicas funcionales

- **Endpoint:** POST /api/v1/auth/login/resend-code. **Request:** { email }. **Response:** { codeDeliveryDetails }.
- El temporizador de 120 s es una salvaguarda del cliente; el backend no aplica cooldown propio, solo el límite de Cognito.

Aclaraciones

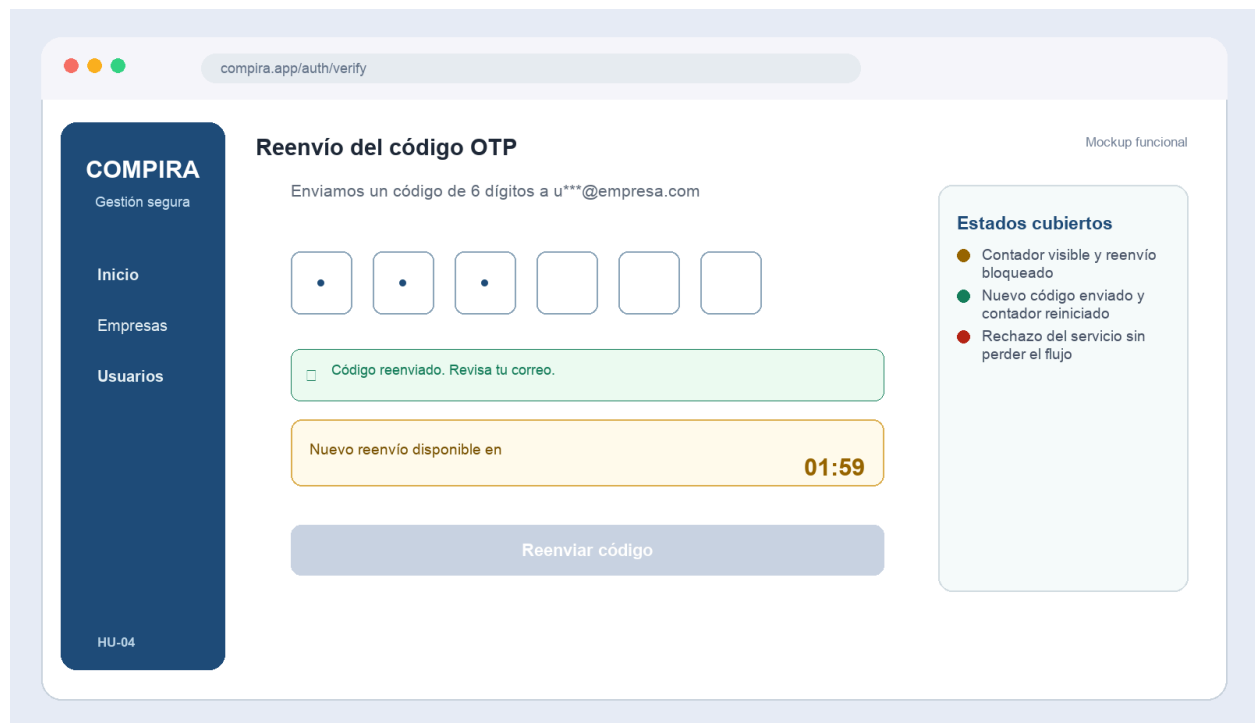
- **[Recomendación]** El cooldown vive solo en el cliente. Si el usuario recarga la página, el contador se reinicia a 120 s. Se recomienda evaluar si esto es aceptable o si debe persistirse. No es criterio de aceptación hasta ser aprobado.

Fuera de alcance

- Reenvío por SMS.

Mockup requerido

Sí. Se representa dentro del mockup de verificación (M-03), estado "esperando" y estado "reenvío disponible".



Mockup funcional HU-04. Incluye los estados principales de uso, validación y error. Elaboración propia (2026).

Dependencias

- Depende de HU-03 (pantalla de verificación).

Preguntas pendientes

1. ¿Debe el contador de reenvío persistir tras recargar la página?
2. ¿Existe un número máximo de reenvíos por sesión definido por negocio?

HU-05. Solicitud de recuperación de contraseña por correo

Sprint S2 | Prioridad Alta | 3 story points | Estado Completado

HISTORIA DE USUARIO - HU-05	
Nombre:	Solicitud de recuperación de contraseña por correo
Puntos de historia (story points):	3
Como (rol):	usuario registrado del sistema (administrador, coordinador o colaborador)
Quiero (funcionalidad):	solicitar la recuperación de mi contraseña desde la pantalla de acceso
Para (beneficio):	restablecer mi ingreso cuando olvido la credencial actual

Contexto funcional

Desde el enlace "Recuperar contraseña" del login, el usuario llega a la pantalla `/auth/password-recovery` (paso 1: "Recuperar contraseña"). Ingresa su correo; si la cuenta existe, Cognito (`forgotPassword`) envía un código al destino configurado y el sistema avanza al paso de confirmación (HU-06).

Campos / Datos involucrados

Campo	Tipo / Control	Obligatorio	Descripción
Correo electrónico	Texto (email)	Sí	Ingresa el correo de la cuenta a recuperar.

Criterios de Aceptación

CA 1. Envío exitoso del código

Cuando el usuario ingresa un correo asociado a una cuenta existente, el sistema solicita el envío del código, muestra el destino enmascarado y avanza al paso de confirmación.

CA 2. Rechazo por correo inválido o vacío

Cuando el correo está vacío, tiene formato inválido o el servicio rechaza la solicitud, el sistema informa el error y no avanza al paso de restablecimiento.

DEFINICIÓN DE TERMINADO (DoD)

- ☐ Código revisado y aprobado por el equipo (code review)
- ☐ Prueba funcional ejecutada y aprobada (caso de prueba documentado)
- ☐ Evidencia visual integrada en el diario de sprint
- ☐ Criterios de aceptación verificados y marcados
- ☐ Sin deuda técnica conocida asociada a esta HU

Escenarios de error

Situación	Mensaje / código
Datos inválidos	AUTH_014 - "La solicitud contiene datos inválidos o incompletos"
Demasiadas solicitudes	AUTH_013
Error inesperado	"Ocurrió un error inesperado. Intenta nuevamente." (UI)

Consideraciones técnicas funcionales

- Endpoint: `POST /api/v1/auth/password-recovery`. Request: { email }. Response: { codeDeliveryDetails }.

Aclaraciones

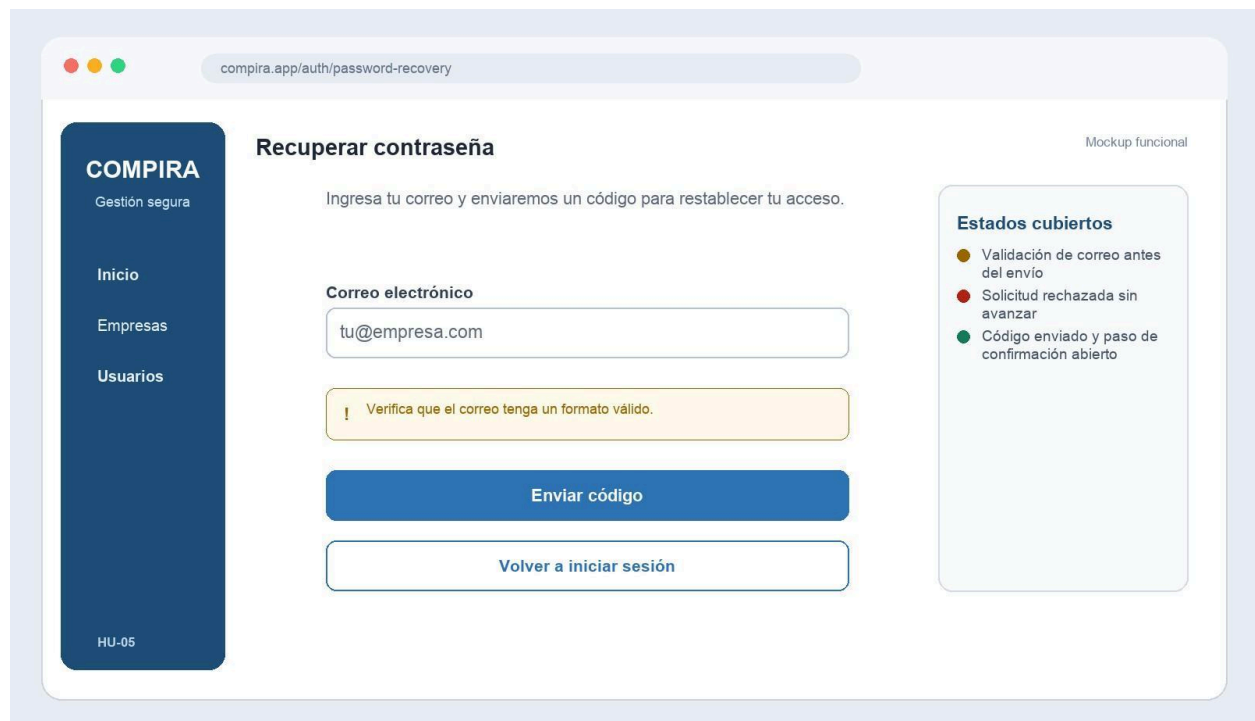
- [Recomendación]** Por seguridad (evitar enumeración de usuarios), suele preferirse una respuesta genérica que no revele si el correo existe. **[Pendiente]** confirmar el comportamiento deseado, ya que hoy el resultado puede diferenciar cuenta existente de inexistente.

Fuera de alcance

- Recuperación mediante preguntas de seguridad u otros canales.

Mockup requerido

Sí. Ver M-04 (paso 1).



Mockup funcional HU-05. Incluye los estados principales de uso, validación y error. Elaboración propia (2026).

Dependencias

- Cognito con `forgotPassword` habilitado y SES configurado.

Preguntas pendientes

1. ¿La respuesta debe ser genérica para no revelar la existencia de la cuenta?

HU-06. Confirmación del restablecimiento de contraseña con código

Sprint S2 | Prioridad Alta | 5 story points | Estado Completado

HISTORIA DE USUARIO - HU-06	
Nombre:	Confirmación del restablecimiento de contraseña con código
Puntos de historia (story points):	5
Como (rol):	usuario registrado del sistema (administrador, coordinador o colaborador)
Quiero (funcionalidad):	confirmar el restablecimiento de mi contraseña con el código recibido y una nueva contraseña
Para (beneficio):	volver a ingresar al sistema con una credencial segura y vigente

Contexto funcional

En el paso 2 de `/auth/password-recovery` ("Restablece tu contraseña"), el usuario ingresa el código de 6 dígitos recibido, la nueva contraseña y su confirmación. Al confirmar (`confirmForgotPassword`), Cognito restablece la contraseña y el sistema muestra el paso 3 ("Contraseña actualizada") con la opción de volver al inicio de sesión.

Campos / Datos involucrados

Campo	Tipo / Control	Obligatorio	Descripción
Código de verificación	Texto numérico (máx. 6 dígitos)	Sí	Ingresar el código recibido por correo.
Nueva contraseña	Texto (password, con mostrar/ocultar)	Sí	Longitud 10-128; debe cumplir la política de Cognito.
Confirmar contraseña	Texto (password)	Sí	Debe coincidir con la nueva contraseña.

Política de contraseña mostrada: mínimo 10 caracteres, una mayúscula, una minúscula, un número y un carácter especial (!@#\$%^&*).

Criterios de Aceptación

CA 1. Restablecimiento exitoso

Quando el usuario ingresa un código válido junto con una nueva contraseña que cumple la política y coincide con su confirmación, el sistema restablece la contraseña y muestra la pantalla de confirmación para regresar al inicio de sesión.

CA 2. Bloqueo del envío por reglas de formato

El envío permanece deshabilitado mientras el código esté vacío, la contraseña no tenga 10-128 caracteres o no coincida con la confirmación (se muestra "Las contraseñas no coinciden").

CA 3. Código incorrecto o expirado

Cuando el código es incorrecto (AUTH_003) o expiró (AUTH_004), el sistema informa el motivo y no cambia la contraseña actual.

CA 4. Contraseña que no cumple la política

Cuando la nueva contraseña no cumple la política de Cognito, el sistema muestra AUTH_002 y no realiza el cambio.

DEFINICIÓN DE TERMINADO (DoD)
☐ Código revisado y aprobado por el equipo (code review)
☐ Prueba funcional ejecutada y aprobada (caso de prueba documentado)
☐ Evidencia visual integrada en el diario de sprint
☐ Criterios de aceptación verificados y marcados
☐ Sin deuda técnica conocida asociada a esta HU

Escenarios de error

Situación	Mensaje / código
Código inválido	AUTH_003 - "El código de confirmación es inválido"
Código expirado	AUTH_004 - "El código de confirmación expiró"
Contraseña no cumple política	AUTH_002 - "La contraseña no cumple con la política definida en Cognito"
Contraseñas no coinciden	"Las contraseñas no coinciden" (UI)

Consideraciones técnicas funcionales

- Endpoint: POST /api/v1/auth/password-recovery/confirm. Request: { email, confirmationCode, newPassword }. Response: 204.

Fuera de alcance

- Reutilización de contraseñas anteriores / historial de contraseñas (no observado; depende de la configuración de Cognito).

Mockup requerido

Sí. Ver M-04 (pasos 2 y 3).

compira.app/auth/password-recovery

COMPIRA
Gestión segura

Inicio
Empresas
Usuarios

HU-06

Restablece tu contraseña

Código de verificación

123456

Nueva contraseña

Confirmar contraseña

Código incorrecto o expirado. Solicita uno nuevo.

Restablecer contraseña

Mockup funcional

Estados cubiertos

- Validación de código y contraseñas
- Código inválido, expirado o política incumplida
- Contraseña actualizada y retorno al login

Mockup funcional HU-06. Incluye los estados principales de uso, validación y error. Elaboración propia (2026).

Dependencias

- Depende de HU-05 (solicitud del código).

Preguntas pendientes

- ¿Cognito está configurado para impedir reutilizar contraseñas recientes?

HU-07. Cierre de sesión y control de acceso a rutas protegidas

Sprint S2 | Prioridad Alta | 3 story points | Estado Completado

HISTORIA DE USUARIO - HU-07	
Nombre:	Cierre de sesión y control de acceso a rutas protegidas
Puntos de historia (story points):	3
Como (rol):	usuario autenticado del sistema
Quiero (funcionalidad):	cerrar mi sesión y mantener protegidas las rutas internas de la plataforma
Para (beneficio):	evitar accesos no autorizados y conservar la seguridad de mi información

Contexto funcional

Mientras exista una sesión válida en el almacenamiento del navegador, el usuario puede navegar por las rutas internas (/ , /users/register, /users/delete). Al cerrar sesión, el sistema limpia los datos locales de autenticación y notifica a Cognito (globalSignOut). Sin sesión válida, cualquier ruta protegida redirige al login.

Campos / Datos involucrados

Elemento	Tipo	Descripción
Cerrar sesión	Acción	Limpia la sesión local e invoca el cierre en Cognito.
Sesión almacenada	Datos en sessionStorage	Claves: compira_access_token, compira_id_token, compira_refresh_token, compira_user.

Criterios de Aceptación

CA 1. Acceso a rutas protegidas con sesión activa

Cuando el usuario tiene una sesión válida, puede acceder a las vistas protegidas mientras la sesión exista en el almacenamiento del navegador.

CA 2. Redirección sin sesión válida

Cuando el usuario no tiene sesión válida e intenta abrir una ruta protegida, el sistema lo redirige a la pantalla de inicio de sesión.

CA 3. Cierre de sesión

Cuando el usuario cierra sesión, el sistema elimina las cuatro claves de autenticación del `sessionStorage`, actualiza el estado a no autenticado y solicita a Cognito el cierre global de la sesión.

CA 4. Cierre local resiliente ante fallo del backend

Cuando el cierre en Cognito falla, el sistema mantiene la sesión cerrada localmente de todas formas (no reexpone la sesión al usuario).

DEFINICIÓN DE TERMINADO (DoD)
☐ Código revisado y aprobado por el equipo (code review)
☐ Prueba funcional ejecutada y aprobada (caso de prueba documentado)
☐ Evidencia visual integrada en el diario de sprint
☐ Criterios de aceptación verificados y marcados
☐ Sin deuda técnica conocida asociada a esta HU

Reglas de negocio

RN 1. La sesión se almacena en `sessionStorage`, por lo que se pierde al cerrar la pestaña o el navegador.

Escenarios de error

Situación	Comportamiento
<code>globalSignOut</code> falla en Cognito	La sesión local ya fue limpiada; el usuario queda deslogueado igualmente.

Consideraciones técnicas funcionales

- Endpoint de logout: `POST /api/v1/auth/logout`. Request: { `accessToken` }. Response: 204.
- Protección de rutas del lado del cliente mediante `ProtectedRoute` (redirige a `/auth/login` si no hay usuario en contexto).

Requerimientos no funcionales

- Seguridad: al no usar `localStorage`, la sesión no persiste entre cierres del navegador.
- [Recomendación]** No existe refresco automático de tokens ni interceptor global que maneje el vencimiento del `accessToken` durante la navegación. Se recomienda evaluar el manejo de expiración de token. No es criterio de aceptación hasta ser aprobado.

Aclaraciones

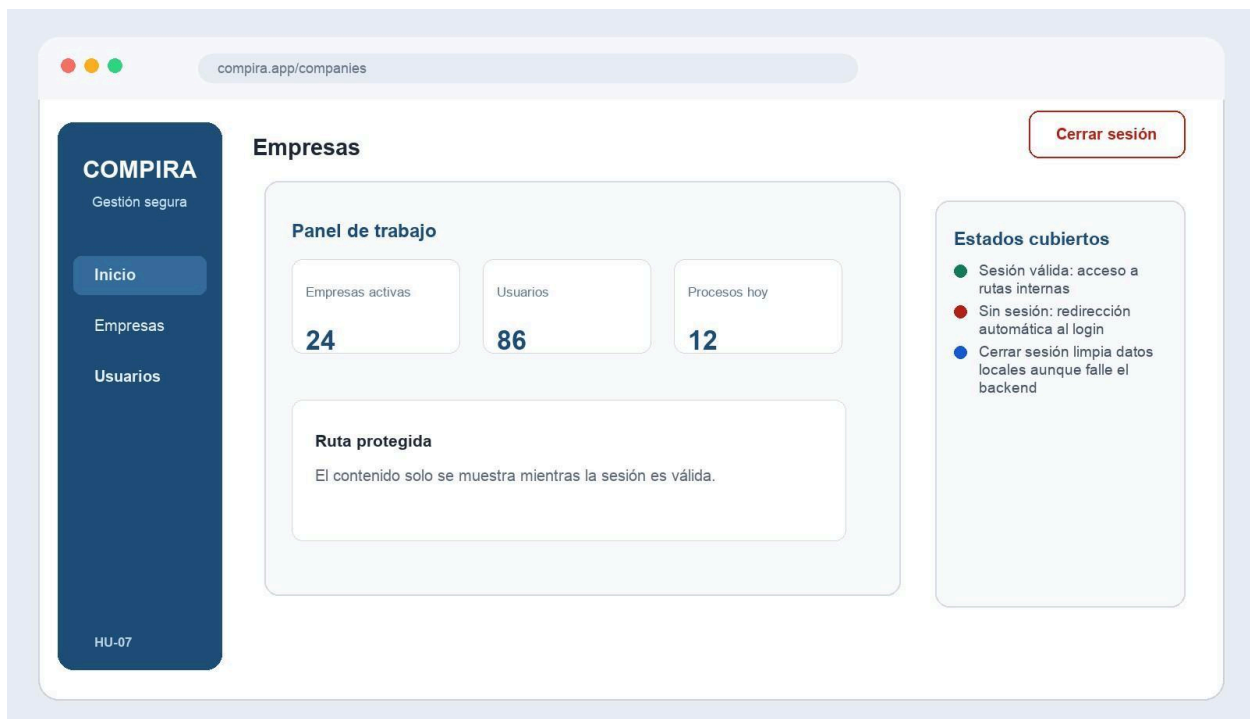
- La protección de rutas es del lado del cliente. La autorización real de cada operación protegida (p. ej. registrar/eliminar usuarios) depende del `accessToken` enviado al backend.

Fuera de alcance

- Cierre de sesión en todos los dispositivos desde una pantalla de gestión.
- Expiración automática por inactividad.

Mockup requerido

Parcial. Ver M-05 (ubicación del control de cierre de sesión y estado de redirección al login). El detalle visual del contenedor autenticado (AppShell) no fue el foco de esta corrección.



Mockup funcional HU-07. Incluye los estados principales de uso, validación y error. Elaboración propia (2026).

Dependencias

- Depende de una sesión previamente establecida (HU-02/HU-03).

Preguntas pendientes

1. ¿Qué debe ocurrir cuando el `accessToken` expira mientras el usuario navega (redirección automática al login, refresco de token)?
2. ¿Se requiere expiración de sesión por inactividad?

HU-08. Registro de usuarios por parte del administrador

Sprint S3 | Prioridad Alta | 5 story points | Estado Completado

HISTORIA DE USUARIO - HU-08	
Nombre:	Registro de usuarios por parte del administrador
Puntos de historia (story points):	5
Como (rol):	administrador del sistema
Quiero (funcionalidad):	registrar nuevos usuarios con sus datos básicos, rol y contraseña temporal
Para (beneficio):	habilitar el acceso de nuevos integrantes con un flujo de activación controlado

Contexto funcional

Desde la pantalla protegida `/users/register`, el administrador diligencia el formulario de registro. El sistema crea el usuario en Cognito (`AdminCreateUser`) con una contraseña temporal, fija sus atributos y su preferencia de MFA, y crea el perfil local. El nuevo usuario deberá cambiar su contraseña temporal en el primer ingreso (HU-01).

Campos / Datos involucrados

Campo	Tipo / Control	Obligatorio	Descripción
Nombre	Texto	Sí	Ingresar el nombre. Máx. 100 caracteres.
Apellido	Texto	Sí	Ingresar el apellido. Máx. 100 caracteres.
Correo electrónico	Texto (email)	Sí	Ingresar el correo. Será el usuario/identificador.
Código de país	Lista desplegable	Sí	Seleccionar el indicativo (por defecto +57).
Teléfono	Texto (solo dígitos)	Sí	Ingresar el número. Se concatena con el indicativo en formato E.164 (^\[1-9]\d{7,14}\$).
Contraseña temporal	Texto (visible)	Sí	Longitud 10-128; debe cumplir la política de Cognito. El usuario la cambiará en el primer ingreso.
Rol	Lista desplegable	Sí	Colaborador / Coordinador / Administrador. Por defecto Colaborador.

Roles válidos (RoleCode): ADMINISTRATOR, COORDINATOR, COLLABORATOR. Canal MFA enviado: EMAIL (fijo desde la UI actual).

Criterios de Aceptación

CA 1. Registro exitoso

Cuando el administrador diligencia correctamente correo, nombre, apellido, teléfono (E.164 válido), rol y contraseña temporal, el sistema crea el usuario, confirma el registro y deja la cuenta lista para el cambio de contraseña en el primer acceso. Se muestra "Usuario <correo> creado correctamente. Recibirá un correo con las instrucciones."

CA 2. Correo duplicado

Cuando el correo ya existe, el sistema no crea el usuario y muestra "Ya existe una cuenta registrada con este correo electrónico" (AUTH_001, conflicto).

CA 3. Datos inválidos

Cuando algún campo obligatorio falta o el teléfono no cumple el formato E.164, el sistema rechaza la creación y muestra el mensaje de validación correspondiente (p. ej. "El número de teléfono debe estar en formato E.164").

CA 4. Contraseña temporal que no cumple la política

Cuando la contraseña temporal no cumple la política de Cognito, el sistema rechaza la creación (AUTH_002).

CA 5. Consistencia ante fallo de persistencia local

Cuando el usuario se crea en Cognito pero falla la persistencia del perfil local, el sistema revierte la creación eliminando el usuario en Cognito y propaga el error, evitando cuentas huérfanas.

CA 6. Rol por defecto

Cuando no se especifica rol, el sistema asigna COLLABORATOR.

DEFINICIÓN DE TERMINADO (DoD)

- ☐ Código revisado y aprobado por el equipo (code review)
- ☐ Prueba funcional ejecutada y aprobada (caso de prueba documentado)
- ☐ Evidencia visual integrada en el diario de sprint
- ☐ Criterios de aceptación verificados y marcados
- ☐ Sin deuda técnica conocida asociada a esta HU

Reglas de negocio

RN 1. El teléfono debe almacenarse en formato E.164 (indicativo + número). **RN 2.** Todo usuario nuevo queda obligado a cambiar su contraseña temporal en el primer ingreso. **RN 3.** El canal de MFA preferido para los usuarios creados desde la UI actual es correo (EMAIL).

Escenarios de error

Situación	Mensaje / código
Correo duplicado	AUTH_001 - "Ya existe una cuenta registrada con este correo electrónico"
Teléfono/campos inválidos	Mensajes de validación (AUTH_014)
Contraseña temporal débil	AUTH_002
Sin token de sesión activo	"No se encontró un token de sesión activo." (UI)

Consideraciones técnicas funcionales

- Endpoint: POST /api/v1/auth/register con header Authorization: Bearer <accessToken>.
- Request: { email, password, firstName, lastName, phoneNumber, preferredMfaChannel: "EMAIL", roleCode }.
- Response: { cognitoSub, userConfirmed, codeDeliveryDetails }.
- Backend: AdminCreateUser (atributos email, email_verified=true, given_name, family_name, phone_number) + AdminSetUserMFAPreference según canal. Rollback de Cognito si falla el guardado local.

Requerimientos no funcionales

- Seguridad / permisos: la operación exige token de acceso. **[Pendiente]** confirmar si el backend restringe además por rol ADMINISTRATOR.
- Trazabilidad: el backend registra creación de usuario con correo enmascarado.

Aclaraciones

- El correo de instrucciones al nuevo usuario lo gestiona Cognito/SES; su contenido no está en el repositorio.
- **[Recomendación]** La contraseña temporal se muestra en texto visible en el formulario. Evaluar si esto es aceptable según la política de seguridad. No es criterio de aceptación hasta ser aprobado.

Fuera de alcance

- Edición de usuarios existentes.
- Confirmación de registro mediante código por el propio usuario (existe un DTO en backend pero no está enrutado ni expuesto en el frontend).

- Selección de canal MFA distinto de correo desde la UI.

Mockup requerido

Sí. Ver M-06.

compira.app/users/register

COMPIRA
Gestión segura

Inicio
Empresas
Usuarios

HU-08

Registrar usuario

Nombre:

Apellido:

Correo electrónico:

Teléfono:

Contraseña temporal: ☐

Rol:

El usuario cambiará esta contraseña en su primer inicio.

Crear usuario

Mockup funcional

Estados cubiertos

- Botón habilitado solo con datos válidos
- Correo duplicado o validación fallida
- Usuario creado y formulario restablecido

Mockup funcional HU-08. Incluye los estados principales de uso, validación y error. Elaboración propia (2026).

Dependencias

- Requiere sesión de administrador activa (token en `sessionStorage`).
- Cognito con `AdminCreateUser`, atributos y SES configurados.

Preguntas pendientes

1. ¿El backend valida que quien registra tenga rol `ADMINISTRATOR`, o basta con un token válido de cualquier rol?
2. ¿Debe generarse la contraseña temporal automáticamente en lugar de que el administrador la escriba?
3. ¿La contraseña temporal tiene periodo de validez antes del primer ingreso?

HU-09. Eliminación de usuarios por correo

Sprint S3 | Prioridad Media | 3 story points | Estado Completado

HISTORIA DE USUARIO - HU-09	
Nombre:	Eliminación de usuarios por correo
Puntos de historia (story points):	3
Como (rol):	administrador del sistema
Quiero (funcionalidad):	eliminar un usuario existente mediante confirmación explícita
Para (beneficio):	retirar accesos que ya no deben permanecer activos en la plataforma

Contexto funcional

Desde la pantalla protegida `/users/delete`, el administrador ingresa el correo del usuario a eliminar. El sistema pide una confirmación explícita antes de proceder. Al confirmar, elimina la cuenta en Cognito (`AdminDeleteUser`) y en la base de datos local. La acción es irreversible.

Campos / Datos involucrados

Campo	Tipo / Control	Obligatorio	Descripción
Correo electrónico del usuario	Texto (email)	Sí	Ingresar el correo del usuario a eliminar.
Confirmar eliminación	Acción	Sí	Segundo paso de confirmación antes de borrar.
Cancelar	Acción	No	Cancela la confirmación sin borrar.

Criterios de Aceptación

CA 1. Eliminación exitosa con confirmación

Cuando el administrador ingresa el correo de un usuario existente y confirma la eliminación, el sistema elimina la cuenta (Cognito y BD local) y muestra "El usuario <correo> ha sido eliminado correctamente."

CA 2. Confirmación previa obligatoria

Antes de eliminar, el sistema muestra un mensaje de confirmación ("¿Estás seguro de eliminar al usuario <correo>? Esta acción no se puede deshacer.") con las opciones "Confirmar eliminación" y "Cancelar".

CA 3. Cancelación

Cuando el administrador cancela, el sistema no elimina ningún registro y cierra el bloque de confirmación.

CA 4. Usuario inexistente

Cuando el correo no corresponde a un usuario existente, el sistema no elimina nada y muestra "No se encontró una cuenta asociada al usuario enviado" (AUTH_007).

DEFINICIÓN DE TERMINADO (DoD)
☐ Código revisado y aprobado por el equipo (code review)
☐ Prueba funcional ejecutada y aprobada (caso de prueba documentado)
☐ Evidencia visual integrada en el diario de sprint
☐ Criterios de aceptación verificados y marcados
☐ Sin deuda técnica conocida asociada a esta HU

Reglas de negocio

RN 1. La eliminación es irreversible y afecta tanto a Cognito como a la base de datos local. **RN 2.** La eliminación requiere una confirmación explícita del administrador.

Escenarios de error

Situación	Mensaje / código
Usuario inexistente	AUTH_007 - "No se encontró una cuenta asociada al usuario enviado"
Sin token de sesión activo	"No se encontró un token de sesión activo." (UI)
Error inesperado	"Ocurrió un error inesperado. Intenta nuevamente." (UI)

Consideraciones técnicas funcionales

- Endpoint: DELETE /api/v1/auth/users con header Authorization: Bearer <accessToken>. Request: { email }. Response: 204.

Requerimientos no funcionales

- Seguridad / permisos: exige token de acceso. **[Pendiente]** confirmar restricción por rol ADMINISTRATOR.
- [Recomendación]** Evaluar registrar en auditoría quién eliminó a qué usuario y cuándo.

Aclaraciones

- La confirmación no exige reescribir el correo; solo confirmar la acción.

Fuera de alcance

- Desactivación temporal (soft delete) de usuarios.
- Eliminación masiva de usuarios.

Mockup requerido

Sí. Ver M-07 (incluye el estado de confirmación).



Mockup funcional HU-09. Incluye los estados principales de uso, validación y error. Elaboración propia (2026).

Dependencias

- Requiere sesión de administrador activa.
- Cognito con `AdminDeleteUser`.

Preguntas pendientes

1. ¿Se requiere borrado lógico (inactivación) en lugar de borrado físico irreversible?
2. ¿Se debe registrar en auditoría la eliminación (quién, cuándo, a quién)?
3. ¿El backend restringe la operación al rol `ADMINISTRATOR`?

4. Preguntas pendientes consolidadas

1. **Política de contraseñas de Cognito:** valor exacto (longitud mínima y clases de caracteres). Hoy la UI exige mínimo 10 y el backend valida mínimo 8; conviene unificar.
2. **Restricción por rol en operaciones de administración:** ¿el backend valida rol `ADMINISTRATOR` para registrar/eliminar usuarios, o basta un token válido de cualquier rol?
3. **Manejo de expiración del token de acceso** durante la navegación (redirección al login vs. refresco automático).
4. **Vigencia del código OTP** de acceso y del código de recuperación.
5. **Persistencia del contador de reenvío** de OTP tras recargar la página y número máximo de reenvíos.
6. **Respuesta genérica en recuperación** para no revelar existencia de la cuenta.
7. **Contraseña temporal:** ¿generación automática vs. ingreso manual por el administrador? ¿periodo de validez? ¿debe mostrarse en texto visible?
8. **Auditoría de eliminación** de usuarios (quién, cuándo, a quién) y borrado lógico vs. físico.
9. **Bloqueo por intentos fallidos** de inicio de sesión.

5. Recomendaciones (no son criterios de aceptación hasta aprobación)

1. Alinear la validación de contraseña del cliente con la política real de Cognito para evitar el error `AUTH_002` tras el envío.
2. Unificar el mínimo de contraseña entre frontend (10) y backend (8).
3. Evaluar manejo de expiración/refresco de tokens e interceptor global de sesión.
4. Persistir el contador de reenvío de OTP o comunicarlo como comportamiento aceptado.
5. Evitar mostrar la contraseña temporal en texto plano en el formulario de registro, o generarla automáticamente.
6. Añadir auditoría para las operaciones sensibles (registro y eliminación de usuarios).
7. Confirmar el control de acceso por rol en el backend para operaciones de administración.

6. Nota de control de cambios

El **reordenamiento del backlog** (HU-01 pasa a ser el cambio de contraseña en primer ingreso) es una **reorganización de presentación**, no altera el alcance funcional ni el esfuerzo de las historias. La sustitución de "reto" por la terminología técnica de desafíos de Cognito es una **corrección de redacción/precisión**. Ninguna de estas correcciones agrega ni elimina alcance respecto del documento base. Las **preguntas pendientes y recomendaciones** podrían derivar en control de cambio solo si, al resolverse, modifican reglas de negocio previamente acordadas.

7. Verificación de cumplimiento de las instrucciones

La revisión final se realizó contra instructions_hu.md. El contenido corregido cumple la estructura funcional solicitada y conserva como pendientes las decisiones que no cuentan con definición aprobada.

Aspecto verificado	Resultado	Evidencia en el documento
Rol, necesidad y beneficio	Cumple	Cada HU conserva la fórmula Como / Quiero / Para en la tabla principal.
Contexto funcional	Cumple	Cada HU explica el proceso, momento de uso, actores y comportamiento esperado.
Campos y datos	Cumple	Se documentan controles, obligatoriedad, formato y descripción mediante tablas.
Criterios verificables por QA	Cumple	Los CA describen condición, acción y resultado observable; se evitan frases ambiguas.
Reglas y escenarios	Cumple	Las reglas se enumeran; se distinguen éxito, errores, mensajes y códigos cuando existen.
Consideraciones técnicas funcionales	Cumple	Se incluyen contratos y endpoints relevantes sin imponer arquitectura interna nueva.
Requerimientos no funcionales	Cumple con pendientes	Seguridad, trazabilidad y rendimiento solo se fijan cuando hay evidencia; lo no definido queda pendiente.
Aclaraciones y fuera de alcance	Cumple	Cada HU delimita comportamientos y evita crecimiento no controlado del alcance.
Mockup requerido	Cumple	Cada HU incorpora su propio mockup con estados de éxito, error, carga, espera o confirmación aplicables.
Dependencias	Cumple	Se listan únicamente módulos, historias, servicios o configuraciones conocidas.
Preguntas y recomendaciones	Cumple	Las preguntas afectan decisiones reales; las recomendaciones están etiquetadas y consolidadas aparte.
No inventar requerimientos	Cumple	La leyenda [Base], [Redacción], [Recomendación] y [Pendiente] separa evidencia, ajustes y decisiones por confirmar.
Gestión de cambios	Cumple	El reordenamiento y la precisión terminológica se clasifican sin ampliar alcance; posibles cambios quedan condicionados a aprobación.

Resultado general: cumple. Las preguntas abiertas no son fallas de la historia; son controles explícitos para evitar que desarrollo, QA o UX/UI deban inventar decisiones funcionales.